

Security Architecture Review Frequently Asked Questions

1. What is a Security Architecture Review?

A Security Architecture Review, or SAR, is a structured review of a system, application, platform, product, or major design change to identify security risks early and ensure the solution aligns with the organization's security requirements.

The SAR focuses on architecture, design, data flows, trust boundaries, authentication, authorization, encryption, logging, third-party integrations, deployment model, and overall security posture.

2. Why is a SAR required?

A SAR helps the organization:

- Identify security risks before implementation or deployment
- Reduce costly redesign or remediation work later
- Ensure consistent security standards across projects
- Protect sensitive data, systems, customers, and business operations
- Support compliance, audit, and risk management requirements
- Improve collaboration between project teams, security, infrastructure, and enterprise architecture

3. When should a SAR be performed?

A SAR should be performed as early as possible, preferably during the planning or design phase and before production deployment.

Projects should not wait until implementation is complete. Early review allows security requirements and design recommendations to be incorporated before major decisions are finalized.

4. What systems, projects, or changes should undergo SAR?

A SAR is generally required for the following:

New systems or applications

Any new internally developed, vendor-provided, cloud-hosted, or third-party system that will be deployed into the organization's environment or used to support business operations.

Architecture or design changes

Major changes to system architecture, application design, hosting model, network segmentation, identity model, data flow, integration pattern, or security control design.

Product deployments

New product deployments, including commercial off-the-shelf products, SaaS platforms, internally developed products, enterprise tools, and business applications.

Enterprise deployments

Solutions intended for broad organizational or enterprise-wide use, including platforms, shared services, infrastructure components, endpoint tools, collaboration platforms, and identity or access management services.

Cloud deployments

New or significantly changed cloud workloads, cloud services, cloud-native applications, container platforms, serverless services, storage platforms, or cloud networking designs.

Systems handling sensitive data

Any system that stores, processes, transmits, or provides access to sensitive, regulated, confidential, personal, financial, health, authentication, or business-critical data.

Internet-facing systems

Any application, service, API, portal, remote access capability, or infrastructure component exposed to the internet or external parties.

Third-party integrations

New integrations with vendors, partners, customers, managed service providers, APIs, data exchanges, or external platforms.

Authentication or authorization changes

Significant changes to login flows, identity providers, single sign-on, privileged access, role-based access control, service accounts, API authentication, or authorization models.

Data movement or integration changes

New or changed data flows between systems, environments, business units, third parties, cloud providers, or geographic regions.

High-risk technology changes

Changes involving encryption, secrets management, remote access, administrative access, artificial intelligence, automation, critical infrastructure, production control systems, or security monitoring capabilities.

5. What does not normally require SAR?

Not every technical change requires a Security Architecture Review. Some changes should follow separate operational, change management, or security review processes.

Examples that generally do not require SAR include:

Firewall rule requests

Firewall rule requests should follow the organization's firewall rule review and approval process, not the SAR process.

However, if the firewall rule is part of a new system, new architecture, new integration, internet-facing deployment, or major design change, the overall project may still require SAR.

Routine patching

Standard operating system, application, appliance, or platform patching does not usually require SAR unless it changes the architecture, exposure, or security model.

Standard vulnerability remediation

Fixing known vulnerabilities usually does not require SAR unless the remediation introduces a major design or architecture change.

Minor configuration changes

Low-risk configuration changes that do not affect system architecture, access model, data flow, internet exposure, or security controls generally do not require SAR.

Standard operational changes

Routine operational work such as account administration, approved access changes, certificate renewal, log review, backup maintenance, or monitoring updates usually does not require SAR.

Break-fix activity

Emergency repair or restoration activity does not normally require SAR. If the fix results in a long-term architecture change, a SAR may be required after stabilization.

6. Do firewall rules ever require SAR?

A firewall rule by itself should not go through SAR. Firewall rule requests should be reviewed through the firewall rule governance process.

A SAR may be required when firewall rules are part of a larger project, such as:

- A new application deployment
- A new internet-facing service
- A new third-party connection
- A new cloud environment
- A new network zone or segmentation model
- A major redesign of traffic flows
- A new data transfer path involving sensitive data

In these cases, SAR reviews the overall architecture and risk, while the firewall process reviews and approves the specific rule implementation.

7. What components does SAR review?

SAR typically reviews the security-relevant architecture components that show how the system works, where risk exists, and what controls protect it.

The components may include the following.

Business and system context

SAR looks for a clear description of:

- What the system does
- Who owns it
- Who uses it
- What business process it supports
- Whether it is business-critical
- Whether it is new, changing, or being expanded

Architecture design

SAR reviews the overall architecture, including:

- Application components
- Infrastructure components
- Cloud services
- Network zones
- Trust boundaries
- Development, test, staging, and production environments
- Shared services and dependencies

- High availability and resiliency design

Data flow

SAR looks for how data moves through the system, including:

- Data sources
- Data destinations
- Internal data flows
- External data flows
- API calls
- File transfers
- Batch jobs
- Messaging queues
- Data replication or synchronization
- Cross-region or cross-border data movement

Data classification and protection

SAR reviews the types of data handled by the system, such as:

- Public data
- Internal data
- Confidential data
- Regulated data
- Personal information
- Financial data
- Health data
- Authentication data
- Secrets, keys, and tokens

SAR also checks whether the data is protected appropriately based on its classification.

Identity and authentication

SAR evaluates how users, administrators, services, and systems authenticate.

This may include:

- Single sign-on
- Multi-factor authentication
- Local accounts
- Service accounts
- API keys
- Certificates
- OAuth or SAML integrations
- Privileged access
- Break-glass accounts

Authorization and access control

SAR looks at how access is granted, limited, and reviewed.

This includes:

- User roles
- Administrator roles
- Role-based access control
- Attribute-based access control
- Least privilege
- Segregation of duties
- Access approval process
- Access review process
- Privileged access management

Network and connectivity design

SAR reviews how the system communicates with other systems.

This includes:

- Internal network connections
- External connections
- Internet exposure
- Inbound and outbound traffic
- Network segmentation
- Private connectivity
- VPN or remote access
- Third-party connectivity
- Firewall zones
- Load balancers
- Reverse proxies
- Web application firewalls

Specific firewall rule requests should still follow the separate firewall rule review process. SAR reviews the architecture and traffic flow, not individual firewall rule approval.

External exposure

SAR identifies whether the system is accessible by:

- The public internet
- Customers
- Vendors
- Partners
- Remote users
- Mobile devices

- APIs
- Third-party platforms

Internet-facing and externally accessible systems usually require closer review because they increase the attack surface.

Application security design

SAR reviews application-level security controls, including:

- Input validation
- Output encoding
- Session management
- Error handling
- Secure API design
- Protection against injection attacks
- Protection against cross-site scripting
- Secure file upload design
- Secure coding practices
- Dependency and package management

API security

For systems using APIs, SAR looks at:

- API authentication
- API authorization
- Rate limiting
- Input validation
- Token handling
- Sensitive data exposure
- API gateway usage
- Logging and monitoring
- Versioning
- External API consumers
- Third-party API integrations

Encryption and key management

SAR reviews whether sensitive data is encrypted appropriately.

This includes:

- Encryption in transit
- Encryption at rest
- Certificate management
- Key ownership
- Key rotation

- Key storage
- Secrets management
- Use of approved cryptographic standards
- Protection of passwords, tokens, and credentials

Logging, monitoring, and detection

SAR looks for security visibility, including:

- Security logs
- Authentication logs
- Administrative activity logs
- API logs
- Access logs
- Error logs
- Audit trails
- Log retention
- Log protection
- Integration with security monitoring tools
- Alerting for suspicious activity

Vulnerability and patch management

SAR reviews how the system will be kept secure after deployment.

This includes:

- Vulnerability scanning
- Patch process
- Dependency scanning
- Container image scanning
- Infrastructure scanning
- Remediation ownership
- Remediation timelines
- Exception handling

Secure configuration

SAR checks whether the system follows secure configuration practices.

This includes:

- Hardened operating systems
- Secure cloud configurations
- Secure database configurations
- Disabled default accounts
- Disabled unnecessary services
- Secure administrative interfaces

- Baseline configuration standards
- Configuration drift monitoring

Cloud security

For cloud-hosted systems, SAR reviews:

- Cloud account or subscription design
- Identity and access management
- Network architecture
- Security groups
- Storage security
- Logging and monitoring
- Cloud-native security controls
- Public exposure
- Encryption
- Secrets management
- Backup and recovery
- Infrastructure as code
- Guardrails and policy enforcement

Third-party and vendor components

SAR reviews vendor, SaaS, and third-party dependencies, including:

- Vendor-hosted platforms
- SaaS applications
- Managed service providers
- Third-party APIs
- Outsourced support access
- Data sharing with vendors
- Vendor security documentation
- Contractual or compliance requirements
- Exit and data deletion considerations

Administrative access

SAR looks closely at administrator access because it creates high risk.

This includes:

- Who has administrative access
- How administrative access is approved
- Whether MFA is required
- Whether privileged access is time-bound
- Whether admin activity is logged
- Whether shared admin accounts are prohibited
- Whether emergency access is controlled

Secrets and credential management

SAR reviews how secrets are created, stored, used, rotated, and retired.

Examples include:

- Passwords
- API keys
- Tokens
- Certificates
- SSH keys
- Database credentials
- Cloud access keys
- Service account credentials

Secrets should not be hardcoded in source code, configuration files, scripts, or documentation.

Environment separation

SAR checks whether environments are properly separated.

This includes:

- Development
- Test
- QA
- Staging
- Production
- Disaster recovery

SAR also reviews whether production data is used in non-production environments and whether access controls differ between environments.

Backup, recovery, and resiliency

SAR reviews how the system can recover from incidents or outages.

This includes:

- Backup process
- Backup encryption
- Backup access controls
- Recovery time objective
- Recovery point objective
- Disaster recovery design
- High availability
- Failover

- Ransomware recovery considerations

Privacy, compliance, and regulatory requirements

SAR may review whether the system supports applicable privacy, legal, regulatory, and compliance needs.

This may include:

- Data minimization
- Data retention
- Data deletion
- Consent requirements
- Audit requirements
- Geographic data restrictions
- Regulatory control requirements

Threat modeling and abuse cases

SAR looks for ways the system could be misused or attacked.

This may include:

- Unauthorized access
- Privilege escalation
- Data leakage
- Account takeover
- Insider misuse
- API abuse
- Denial of service
- Fraud scenarios
- Supply chain risk
- Misconfiguration risk

Security testing requirements

SAR may identify required testing before production release, such as:

- Vulnerability scanning
- Static application security testing
- Dynamic application security testing
- Software composition analysis
- Penetration testing
- Cloud configuration review
- Container security review
- Infrastructure security review

Risk, exceptions, and compensating controls

SAR reviews any known security gaps and determines whether they require:

- Remediation
- Compensating controls
- Conditional approval
- Risk acceptance
- Additional review
- Follow-up after deployment

Operational ownership

SAR confirms that the system has clear ownership after deployment.

This includes:

- Business owner
- Technical owner
- Support team
- Security contact
- Incident response contact
- Patch owner
- Access review owner
- Logging and monitoring owner
- Vendor management owner, if applicable

8. What is the difference between SAR and change management?

Change management focuses on controlling and approving implementation activities, scheduling, operational impact, and rollback planning.

SAR focuses on security design and architecture risk before or during the design phase.

A project may require both SAR and change management approval. SAR approval does not replace change approval, and change approval does not replace SAR.

9. What is the difference between SAR and vulnerability scanning?

Vulnerability scanning identifies known technical weaknesses in deployed systems, applications, or infrastructure.

SAR evaluates the design and architecture before or during implementation. It looks at whether the system is designed securely, even before vulnerabilities are introduced or discovered.

Both activities are important and may be required for the same project.

10. What is the difference between SAR and penetration testing?

Penetration testing evaluates whether a system can be exploited under defined test conditions.

SAR evaluates whether the system architecture is secure, appropriate, and aligned with security standards.

A high-risk system may require SAR before deployment and penetration testing before or after go-live.

11. Who is responsible for requesting a SAR?

The project owner, system owner, product owner, technical lead, architect, or implementation team is responsible for requesting a SAR when a project meets the review criteria.

Security, enterprise architecture, infrastructure, cloud, risk, or compliance teams may also require a SAR if they identify that a project introduces security architecture risk.

12. Who participates in a SAR?

Participants may include:

- System owner or business owner
- Product owner or project manager
- Solution architect or enterprise architect
- Application or engineering team
- Infrastructure, network, or cloud team
- Identity and access management team
- Security architecture team
- Security operations or monitoring team
- Risk, compliance, privacy, or legal representatives when needed
- Vendor or third-party representatives when applicable

13. What information is needed for a SAR?

The requesting team should provide enough information for security to understand the architecture and risk.

Typical information includes:

- Business purpose and system overview
- Architecture diagrams
- Data flow diagrams
- Network diagrams, if applicable
- Hosting location and deployment model
- Cloud services used, if applicable
- Data classification and types of data handled

- User groups and access model
- Authentication and authorization design
- External connections and third-party integrations
- API details, if applicable
- Encryption approach
- Logging and monitoring approach
- Backup and recovery approach
- Administrative access model
- Known risks, exceptions, or open design questions
- Planned go-live date

14. What questions does the SAR process try to answer?

A SAR typically evaluates questions such as:

- What data does the system store, process, or transmit?
- Who can access the system?
- How are users and administrators authenticated?
- How is access authorized and reviewed?
- What systems does it connect to?
- Is it internet-facing or externally accessible?
- What trust boundaries exist?
- Is sensitive data encrypted in transit and at rest?
- How are secrets, keys, and credentials protected?
- How are logs generated, protected, and monitored?
- What are the main abuse cases or threat scenarios?
- What security controls reduce the identified risks?
- Are there unresolved risks requiring acceptance or remediation?

15. What are the possible SAR outcomes?

A SAR may result in one or more of the following outcomes:

- Approved with no additional security actions
- Approved with required security conditions
- Approved with recommended improvements
- Conditional approval pending remediation
- Risk acceptance required
- Additional review required
- Not approved due to unacceptable security risk

16. Does SAR approval mean the system is fully secure?

No. SAR approval means the architecture has been reviewed and the identified risks, controls, and required actions have been assessed at the time of review.

SAR approval does not guarantee that a system is free of vulnerabilities or operational issues. Additional activities such as secure coding, vulnerability scanning, penetration testing, configuration review, privacy review, compliance review, and change management may still be required.

17. Is SAR required for vendor or SaaS products?

Yes, a SAR may be required for vendor or SaaS products when they introduce new business capabilities, process sensitive data, integrate with enterprise systems, provide broad organizational access, or create new security dependencies.

The SAR for vendor or SaaS products may review:

- Data handled by the vendor
- Identity and single sign-on integration
- Administrative roles
- Logging and audit capabilities
- Data retention and deletion
- Encryption
- API integrations
- Network connectivity
- Tenant configuration
- Vendor security documentation
- Exit strategy and data portability

18. Is SAR required for proof-of-concept or pilot deployments?

A SAR may be required for proof-of-concept or pilot deployments if the activity involves sensitive data, external connectivity, production access, enterprise authentication, privileged access, or deployment into a production or shared environment.

Low-risk lab testing using non-sensitive data in an isolated environment may not require a full SAR, but the security team should be consulted when there is uncertainty.

19. Is SAR required for AI or automation solutions?

A SAR should be considered for AI, machine learning, robotic process automation, workflow automation, or decision-support systems when they access sensitive data, interact with production systems, make or recommend business decisions, integrate with enterprise applications, or expose data to third-party platforms.

The review should consider data protection, model access, prompt or input handling, output validation, logging, user access, vendor risk, and misuse scenarios.

20. What happens if a project skips SAR?

If a project that requires SAR skips the review, it may face delayed deployment, additional remediation requirements, risk acceptance, audit findings, or production restrictions.

Skipping SAR may also increase the likelihood of security weaknesses, compliance issues, and costly redesign.

21. How long does a SAR take?

The timeline depends on the complexity of the system, completeness of the submitted information, risk level, and availability of project stakeholders.

Simple reviews may be completed quickly. Complex enterprise, cloud, internet-facing, or sensitive-data systems may require deeper review, additional meetings, or follow-up actions.

22. How can teams make the SAR process faster?

Teams can help by:

- Engaging security early
- Providing complete architecture and data flow diagrams
- Clearly documenting data types and data classification
- Identifying users, administrators, and access paths
- Explaining integrations and external connections
- Documenting security controls already planned
- Highlighting open questions or known risks
- Avoiding last-minute review requests before go-live

23. What should be included in the SAR request?

A SAR request should include:

- Project or system name
- Business owner and technical owner
- Description of the system or change
- Target deployment date
- Environment details
- Architecture diagram
- Data flow diagram
- Data classification
- User and administrator access model
- Internal and external integrations
- Internet exposure, if any
- Cloud, vendor, or third-party involvement
- Security requirements already identified

- Open risks or design decisions needing review

24. Is SAR a one-time activity?

Not always. A system may need another SAR when there is a significant architecture, design, deployment, integration, data, or access change.

Examples include:

- Moving from on-premises to cloud
- Adding internet-facing access
- Adding sensitive data processing
- Changing authentication or authorization models
- Integrating with a new third party
- Expanding from limited use to enterprise-wide deployment
- Re-architecting major components
- Introducing new administrative capabilities

25. How does SAR relate to risk acceptance?

If a risk cannot be remediated before deployment, the security team may require formal risk acceptance by the appropriate business or risk owner.

Risk acceptance should document the risk, business justification, compensating controls, expiration or review date, and accountable owner.

26. What is the main rule of thumb?

If a change affects system architecture, design, deployment model, data flow, authentication, authorization, sensitive data, external exposure, third-party integration, or enterprise-wide use, it should be evaluated for SAR.

If the request is only a routine firewall rule change, patch, minor configuration update, or standard operational task, it should usually follow the appropriate operational process instead of SAR.